API test cases — HitBox Collectibles operations console

Date: 18 September 2026
Base URL: `http://localhost:3000` (Next ingress at `/api/hitbox/*` → `<HITBOX_API_URL>/api/v1/*`)
Endpoints under test: 88
Generated by: `npm run docs:api-cases` — do not edit by hand

How to read this

This document is **generated**, not written. The case list comes from the Playwright suite itself (`playwright test --list`), so a case cannot appear here without existing in the code. The **Observed** column is a live probe run at generation time, not a transcription — every endpoint below was actually called and its real status recorded.

Every probe is unauthenticated. The ingress refuses those before any upstream call, so generating this document changes nothing, on any environment — including one pointed at production.

Cases that need a Clerk session are listed with their IDs and marked **NOT EXECUTED** rather than left out. The gap is part of the report.

Result

```
88 endpoints probed
88 refused to an anonymous caller
0 leaked data
0 unreachable
```

KIND	COUNT	MEANING	PROBED FOR
`read`	49	Safe to call anywhere	Refusal (unauth)
`write`	16	Creates or edits a record	Refusal only — never a success path
`act`	23	Advances a state machine — money or ownership moves	Refusal only — never a success path

All 88 endpoints refused the anonymous caller, and none returned a row. That is exhaustive, not a sample — every endpoint the console can call was tried, including the ones that move money and change ownership.

Method

Each endpoint is called once, unauthenticated, with:

- `redirect: "manual"` — following the redirect is exactly what hides the refusal. A redirect chain ending at the sign-in page answers **200**, and a matrix that accepted that would record a wide-open API as secure. (This is how finding #1 in the E2E report surfaced.)
- **a concrete, non-existent id** for parameterised paths (`00000000-0000-0000-0000-000000000000`), so a refusal cannot depend on the record existing — if it ever did, that would itself be the finding.
- **a JSON body** on every verb that takes one, so a refusal cannot depend on the body being absent.

A pass requires the status to be one of `301 302 303 307 308 401 403 404` **and** the body to contain no `data` / `items` / `total` key, no `Bearer` token, no `sk_` secret and no JWT.

Matrix — unauthenticated refusal

ID	METHOD	ENDPOINT	KIND	BACKEND GUARD	OBSERVED	LEAK	RESULT
API-UNAUTH-001	`GET`	`authz/me`	read	`–`	`307` → /sign-in	none	PASS
API-UNAUTH-002	`GET`	`admin/dashboard`	read	`reports-dashboards:read`	`307` → /sign-in	none	PASS
API-UNAUTH-003	`GET`	`admin/dashboard/users`	read	`buyer-profile:read`	`307` → /sign-in	none	PASS
API-UNAUTH-004	`GET`	`admin/dashboard/finance`	read	`payment-royalty:read`	`307` → /sign-in	none	PASS
API-UNAUTH-005	`GET`	`admin/dashboard/markets`	read	`reports-dashboards:read`	`307` → /sign-in	none	PASS
API-UNAUTH-006	`GET`	`admin/dashboard/orders`	read	`order:read`	`307` → /sign-in	none	PASS
API-UNAUTH-007	`GET`	`admin/dashboard/products`	read	`drop:read`	`307` → /sign-in	none	PASS
API-UNAUTH-008	`GET`	`admin/dashboard/release-approvals`	read	`release-approval:read`	`307` → /sign-in	none	PASS
API-UNAUTH-009	`GET`	`admin/dashboard/provenance`	read	`collectible-instance:read`	`307` → /sign-in	none	PASS
API-UNAUTH-010	`GET`	`admin/dashboard/supply`	read	`drop:read`	`307` → /sign-in	none	PASS
API-UNAUTH-011	`GET`	`admin/dashboard/resale`	read	`order:read`	`307` → /sign-in	none	PASS
API-UNAUTH-012	`GET`	`admin/dashboard/demand-signals`	read	`drop:read`	`307` → /sign-in	none	PASS
API-UNAUTH-013	`GET`	`admin/authz/roles`	read	`employee-role-mgmt:read`	`307` → /sign-in	none	PASS
API-UNAUTH-014	`GET`	`admin/authz/roles/:roleId`	read	`employee-role-mgmt:read`	`307` → /sign-in	none	PASS
API-UNAUTH-015	`GET`	`admin/authz/permissions`	read	`employee-role-mgmt:read`	`307` → /sign-in	none	PASS

ID	METHOD	ENDPOINT	KIND	BACKEND GUARD	OBSERVED	LEAK	RESULT
API-UNAUTH-016	`GET`	`admin/authz/team`	read	`employee-role-mgmt:read`	`307` → /sign-in	none	PASS
API-UNAUTH-017	`POST`	`admin/authz/roles`	write	`employee-role-mgmt:manage`	`307` → /sign-in	none	PASS
API-UNAUTH-018	`PATCH`	`admin/authz/roles/:roleId`	write	`employee-role-mgmt:manage`	`307` → /sign-in	none	PASS
API-UNAUTH-019	`DELETE`	`admin/authz/roles/:roleId`	write	`employee-role-mgmt:manage`	`307` → /sign-in	none	PASS
API-UNAUTH-020	`POST`	`admin/authz/users/:userId/roles`	act	`employee-role-mgmt:manage`	`307` → /sign-in	none	PASS
API-UNAUTH-021	`DELETE`	`admin/authz/users/:userId/roles/:assignmentId`	act	`employee-role-mgmt:manage`	`307` → /sign-in	none	PASS
API-UNAUTH-022	`GET`	`admin/orders`	read	`order:read`	`307` → /sign-in	none	PASS
API-UNAUTH-023	`GET`	`admin/orders/:orderId`	read	`order:read`	`307` → /sign-in	none	PASS
API-UNAUTH-024	`PATCH`	`admin/orders/:orderId/status`	act	`order:manage`	`307` → /sign-in	none	PASS
API-UNAUTH-025	`GET`	`admin/products`	read	`drop:read`	`307` → /sign-in	none	PASS
API-UNAUTH-026	`GET`	`admin/products/:productId`	read	`drop:read`	`307` → /sign-in	none	PASS
API-UNAUTH-027	`GET`	`admin/products/:productId/skus`	read	`collectible-instance:read`	`307` → /sign-in	none	PASS
API-UNAUTH-028	`GET`	`admin/products/:productId/skus/summary`	read	`collectible-instance:read`	`307` → /sign-in	none	PASS
API-UNAUTH-029	`GET`	`admin/products/:productId/images`	read	`drop:read`	`307` → /sign-in	none	PASS
API-UNAUTH-030	`GET`	`admin/skus`	read	`collectible-instance:read`	`307` → /sign-in	none	PASS
API-UNAUTH-031	`GET`	`admin/skus/:skuId`	read	`collectible-instance:read`	`307` → /sign-in	none	PASS

ID	METHOD	ENDPOINT	KIND	BACKEND GUARD	OBSERVED	LEAK	RESULT
API-UNAUTH-032	GET	admin/skus/code/:skuCode	read	collectible-instance:read	307 → /sign-in	none	PASS
API-UNAUTH-033	POST	admin/products	write	drop:manage	307 → /sign-in	none	PASS
API-UNAUTH-034	PATCH	admin/products/:productId	write	drop:manage	307 → /sign-in	none	PASS
API-UNAUTH-035	DELETE	admin/products/:productId	write	drop:manage	307 → /sign-in	none	PASS
API-UNAUTH-036	POST	admin/products/:productId/images	write	drop:manage	307 → /sign-in	none	PASS
API-UNAUTH-037	PUT	admin/products/:productId/images	write	drop:manage	307 → /sign-in	none	PASS
API-UNAUTH-038	DELETE	admin/products/:productId/images/:imageId	write	drop:manage	307 → /sign-in	none	PASS
API-UNAUTH-039	POST	admin/products/:productId/skus	act	collectible-instance:manage	307 → /sign-in	none	PASS
API-UNAUTH-040	POST	admin/products/:productId/skus/tags	act	nfc-tag-claim:manage	307 → /sign-in	none	PASS
API-UNAUTH-041	POST	admin/skus/:skuId/tag	act	nfc-tag-claim:manage	307 → /sign-in	none	PASS
API-UNAUTH-042	GET	admin/releases	read	release-approval:read	307 → /sign-in	none	PASS
API-UNAUTH-043	GET	admin/releases/:approvalId	read	release-approval:read	307 → /sign-in	none	PASS
API-UNAUTH-044	POST	admin/releases	act	release-approval:manage	307 → /sign-in	none	PASS
API-UNAUTH-045	PATCH	admin/releases/:approvalId	act	release-approval:manage	307 → /sign-in	none	PASS
API-UNAUTH-046	POST	admin/releases/:approvalId/decision	act	release-approval:manage	307 → /sign-in	none	PASS
API-UNAUTH-047	GET	admin/markets	read	reports-dashboards:read	307 → /sign-in	none	PASS

ID	METHOD	ENDPOINT	KIND	BACKEND GUARD	OBSERVED	LEAK	RESULT
API-UNAUTH-048	`GET`	`admin/markets/:marketId`	read	`reports-dashboards:read`	`307` → /sign-in	none	PASS
API-UNAUTH-049	`POST`	`admin/markets`	write	`reports-dashboards:manage`	`307` → /sign-in	none	PASS
API-UNAUTH-050	`PATCH`	`admin/markets/:marketId`	write	`reports-dashboards:manage`	`307` → /sign-in	none	PASS
API-UNAUTH-051	`DELETE`	`admin/markets/:marketId`	write	`reports-dashboards:manage`	`307` → /sign-in	none	PASS
API-UNAUTH-052	`GET`	`admin/media`	read	`assets-documents-upload:read`	`307` → /sign-in	none	PASS
API-UNAUTH-053	`GET`	`admin/media/:assetId/url`	read	`assets-documents-upload:read`	`307` → /sign-in	none	PASS
API-UNAUTH-054	`DELETE`	`admin/media/:assetId`	write	`assets-documents-upload:manage`	`307` → /sign-in	none	PASS
API-UNAUTH-055	`GET`	`admin/finance/royalty-rules`	read	`payment-royalty:read`	`307` → /sign-in	none	PASS
API-UNAUTH-056	`GET`	`admin/finance/royalty-entries`	read	`payment-royalty:read`	`307` → /sign-in	none	PASS
API-UNAUTH-057	`GET`	`admin/finance/royalty-entries/:entryId`	read	`payment-royalty:read`	`307` → /sign-in	none	PASS
API-UNAUTH-058	`GET`	`admin/finance/balances`	read	`payment-royalty:read`	`307` → /sign-in	none	PASS
API-UNAUTH-059	`GET`	`admin/finance/payouts`	read	`payment-royalty:read`	`307` → /sign-in	none	PASS
API-UNAUTH-060	`GET`	`admin/finance/payouts/:payoutId`	read	`payment-royalty:read`	`307` → /sign-in	none	PASS
API-UNAUTH-061	`GET`	`admin/finance/adjustments`	read	`payment-royalty:read`	`307` → /sign-in	none	PASS
API-UNAUTH-062	`GET`	`admin/finance/ledger`	read	`payment-royalty:read`	`307` → /sign-in	none	PASS
API-UNAUTH-063	`POST`	`admin/finance/royalty-rules`	write	`payment-royalty:manage`	`307` → /sign-in	none	PASS

ID	METHOD	ENDPOINT	KIND	BACKEND GUARD	OBSERVED	LEAK	RESULT
API-UNAUTH-064	POST	admin/finance/royalty-rules/:ruleId/close	act	payment-royalty:manage	307 → /sign-in	none	PASS
API-UNAUTH-065	POST	admin/finance/royalty-entries/:entryId/reverse	act	payment-royalty:override	307 → /sign-in	none	PASS
API-UNAUTH-066	POST	admin/finance/payouts	act	payment-royalty:manage	307 → /sign-in	none	PASS
API-UNAUTH-067	POST	admin/finance/payouts/:payoutId/approve	act	payment-royalty:manage	307 → /sign-in	none	PASS
API-UNAUTH-068	POST	admin/finance/payouts/:payoutId/execute	act	payment-royalty:manage	307 → /sign-in	none	PASS
API-UNAUTH-069	POST	admin/finance/payouts/:payoutId/fail	act	payment-royalty:manage	307 → /sign-in	none	PASS
API-UNAUTH-070	POST	admin/finance/adjustments	act	payment-royalty:manage	307 → /sign-in	none	PASS
API-UNAUTH-071	GET	admin/payments/transactions	read	payment-royalty:read	307 → /sign-in	none	PASS
API-UNAUTH-072	GET	admin/payments/transactions/:paymentId	read	payment-royalty:read	307 → /sign-in	none	PASS
API-UNAUTH-073	GET	admin/payments/refunds	read	payment-royalty:read	307 → /sign-in	none	PASS
API-UNAUTH-074	GET	admin/payments/refunds/:refundId	read	payment-royalty:read	307 → /sign-in	none	PASS
API-UNAUTH-075	GET	admin/payments/disputes	read	payment-royalty:read	307 → /sign-in	none	PASS
API-UNAUTH-076	GET	admin/payments/disputes/:disputeId	read	payment-royalty:read	307 → /sign-in	none	PASS
API-UNAUTH-077	GET	admin/payments/gateway-configs	read	payment-royalty:configure	307 → /sign-in	none	PASS
API-UNAUTH-078	GET	admin/payments/webhook-events	read	payment-royalty:read	307 → /sign-in	none	PASS
API-UNAUTH-079	POST	admin/payments/transactions/:paymentId/review	act	payment-royalty:manage	307 → /sign-in	none	PASS

ID	METHOD	ENDPOINT	KIND	BACKEND GUARD	OBSERVED	LEAK	RESULT
API-UNAUTH-080	`POST`	`admin/payments/refunds/:refundId/confirm-return`	act	`order:refund` + `payment-royalty`	`307` → /sign-in	none	PASS
API-UNAUTH-081	`POST`	`admin/payments/refunds/:refundId/approve`	act	`order:refund` + `payment-royalty`	`307` → /sign-in	none	PASS
API-UNAUTH-082	`POST`	`admin/payments/refunds/:refundId/reject`	act	`order:refund` + `payment-royalty`	`307` → /sign-in	none	PASS
API-UNAUTH-083	`POST`	`admin/payments/refunds/:refundId/process`	act	`order:refund` + `payment-royalty`	`307` → /sign-in	none	PASS
API-UNAUTH-084	`POST`	`admin/payments/disputes`	write	`payment-royalty:manage`	`307` → /sign-in	none	PASS
API-UNAUTH-085	`POST`	`admin/payments/disputes/:disputeId/evidence`	act	`payment-royalty:manage`	`307` → /sign-in	none	PASS
API-UNAUTH-086	`POST`	`admin/payments/disputes/:disputeId/resolve`	act	`payment-royalty:manage`	`307` → /sign-in	none	PASS
API-UNAUTH-087	`PATCH`	`admin/payments/gateway-configs/:configId`	write	`payment-royalty:configure`	`307` → /sign-in	none	PASS
API-UNAUTH-088	`GET`	`admin/audit-logs`	read	`audit-log:read`	`307` → /sign-in	none	PASS

Endpoints that move money or ownership

The `act` rows above are the ones worth naming individually, because a regression on any of them is not a data-exposure bug — it is an unauthenticated stranger able to pay out a balance or revoke a collector's ownership:

ENDPOINT	WHAT A SUCCESSFUL ANONYMOUS CALL WOULD DO
`POST admin/finance/payouts/:payoutId/execute`	Pay real money to a real person
`POST admin/payments/refunds/:refundId/process`	Revoke ownership, quarantine the tag, send money, reverse the royalty
`POST admin/finance/royalty-entries/:entryId/reverse`	Cancel money someone is owed
`PATCH admin/orders/:orderId/status`	Desynchronise an order from its payment
`POST admin/authz/users/:userId/roles`	Grant themselves any role in the catalog
`DELETE admin/authz/roles/:roleId`	Delete a role out from under everyone holding it

All 23 `act` endpoints are in the matrix above with their observed results.

Ingress behaviour

Beyond per-endpoint refusal, the ingress itself is asserted (`e2e/specs/public/api-surface.spec.ts` , `api-ingress.spec.ts`):

GROUP	CASES
API surface — every endpoint refuses an anonymous caller	88
The refusal is the proxy's, not the backend's	12
Query handling at the ingress	4
Read endpoints are enumerable but not readable	1

ID	CASE	STATUS
ING-001	answers a JSON 401 the client can map to a message	**KNOWN DEFECT** — proxy 307s API routes to /sign-in, so the handler's JSON 401 is unreachable
ING-002	GET /api/hitbox/authz/me is refused before it reaches the backend	PASS
ING-003	GET /api/hitbox/admin/orders is refused before it reaches the backend	PASS
ING-004	GET /api/hitbox/admin/finance/balances is refused before it reaches the backend	PASS
ING-005	GET /api/hitbox/admin/authz/roles is refused before it reaches the backend	PASS
ING-006	GET /api/hitbox/admin/audit-logs is refused before it reaches the backend	PASS
ING-007	a write is refused at the door, not forwarded upstream	PASS
ING-008	the refusal leaks no token and no upstream origin	PASS
ING-009	the backend origin is never named in a client-visible response	PASS
ING-010	the Clerk session cookie is not readable from page scripts	PASS

Contract cases — require a session (NOT EXECUTED)

`e2e/specs/authed/api-contract.spec.ts`. These check what `src/lib/api/client.ts` and `hooks.ts` read directly and would break quietly without. They are not a re-test of the backend's business logic — that is the backend's suite to own.

ID	GROUP	CASE	STATUS
API-AUTH-001	Envelope	every readable collection answers JSON with a data envelope	NOT EXECUTED — no session
API-AUTH-002	Envelope	an error carries the documented { error: { code, message, details } }	NOT EXECUTED — no session
API-AUTH-003	Envelope	a not-found answers a documented NOT_FOUND-family code	NOT EXECUTED — no session
API-AUTH-004	The omission rule	the dashboard omits withheld sections rather than nulling them	NOT EXECUTED — no session
API-AUTH-005	The omission rule	growthPercentage is a number or null, never a string	NOT EXECUTED — no session

ID	GROUP	CASE	STATUS
API-AUTH-006	Pagination	admin/orders honours page and pageSize	NOT EXECUTED — no session
API-AUTH-007	Pagination	admin/products honours page and pageSize	NOT EXECUTED — no session
API-AUTH-008	Pagination	admin/releases honours page and pageSize	NOT EXECUTED — no session
API-AUTH-009	Pagination	admin/markets honours page and pageSize	NOT EXECUTED — no session
API-AUTH-010	Pagination	admin/audit-logs honours page and pageSize	NOT EXECUTED — no session
API-AUTH-011	Pagination	admin/finance/royalty-entries honours page and pageSize	NOT EXECUTED — no session
API-AUTH-012	Pagination	admin/payments/transactions honours page and pageSize	NOT EXECUTED — no session
API-AUTH-013	Pagination	page 2 is not page 1 again	NOT EXECUTED — no session
API-AUTH-014	Filters reach the server	an order status filter narrows the result set	NOT EXECUTED — no session
API-AUTH-015	Filters reach the server	an invalid range is refused rather than silently swapped	NOT EXECUTED — no session
API-AUTH-016	Scope and masking	a masked grant does not return unmasked personal data	NOT EXECUTED — no session
API-AUTH-017	Scope and masking	/authz/me returns only permissions this catalog can parse	NOT EXECUTED — no session
API-AUTH-018	Write endpoints refuse what they should	no write acts on an empty body	NOT EXECUTED — no session
API-AUTH-019	Write endpoints refuse what they should	a 422 carries details naming the offending field	NOT EXECUTED — no session
API-AUTH-020	Reads are genuinely read-only	every parameterless read answers identically twice	NOT EXECUTED — no session

Workflow cases — require a session (NOT EXECUTED)

`e2e/specs/authed/workflows.spec.ts`. Read-only and negative by decision: nothing advances a state machine. What they assert is agreement between what the UI offers and what the server's `allowedTransitions` permits, plus the refusals.

ID	WORKFLOW	CASE	STATUS
WF-001	Workflow inventory	every workflow has a screen an operator can reach	NOT EXECUTED — no session
WF-002	Refund workflow	the buttons offered match the server's allowedTransitions	NOT EXECUTED — no session
WF-003	Refund workflow	approving before the return is confirmed demands an explicit override	NOT EXECUTED — no session

ID	WORKFLOW	CASE	STATUS
WF-004	Refund workflow	rejecting requires a reason	NOT EXECUTED — no session
WF-005	Refund workflow	process is presented as the irreversible step it is	NOT EXECUTED — no session
WF-006	Refund workflow	an illegal transition is refused by the server	NOT EXECUTED — no session
WF-007	Refund workflow	the full four-step path	NOT EXECUTED — gated behind E2E_ALLOW_WRITES
WF-008	Payout workflow	payout actions are offered only on a global manage grant	NOT EXECUTED — no session
WF-009	Payout workflow	execute is guarded by a confirmation	NOT EXECUTED — no session
WF-010	Payout workflow	scheduling a run with nothing eligible says so	NOT EXECUTED — no session
WF-011	Payout workflow	the full lifecycle	NOT EXECUTED — gated behind E2E_ALLOW_WRITES
WF-012	Release approval workflow	a rejection cannot be submitted without a comment	NOT EXECUTED — no session
WF-013	Release approval workflow	an already-decided review does not offer a second decision	NOT EXECUTED — no session
WF-014	Release approval workflow	an age-restricted drop cannot be approved without a minimum age	NOT EXECUTED — no session
WF-015	Order lifecycle	PAID and REFUNDED are never offered by hand	NOT EXECUTED — no session
WF-016	Order lifecycle	an invalid transition is refused by the server	NOT EXECUTED — no session
WF-017	Royalty reversal	reverse is offered only on an exact override grant	NOT EXECUTED — no session
WF-018	Royalty reversal	an already-reversed entry cannot be reversed again	NOT EXECUTED — no session
WF-019	Royalty reversal	ledger rows are immutable	NOT EXECUTED — no session
WF-020	Role lifecycle	a seeded role cannot be deleted from the UI	NOT EXECUTED — no session
WF-021	Role lifecycle	a role still assigned cannot be deleted	NOT EXECUTED — no session
WF-022	Role lifecycle	a permission outside the role's domain cannot be selected	NOT EXECUTED — no session
WF-023	Role assignment	an organization-scoped role demands an organization	NOT EXECUTED — no session
WF-024	Role assignment	a duplicate assignment is refused	NOT EXECUTED — no session
WF-025	Minting and tag binding	the units surface refuses PUBLIC and OWN scope holders	NOT EXECUTED — no session

ID	WORKFLOW	CASE	STATUS
WF-026	Minting and tag binding	binding a tag needs nfc-tag-claim:manage, not just a mint grant	NOT EXECUTED — no session
WF-027	Minting and tag binding	minting past declared supply is refused	NOT EXECUTED — no session
WF-028	Gateway configuration	credentials are never rendered back to the browser	NOT EXECUTED — no session

Cases whose name implies a write (the full refund path, the payout lifecycle, minting) are additionally gated behind `E2E_ALLOW_WRITES=1` and will not run even with a session unless that is set deliberately, against a seeded backend.

What this run does and does not prove

Proves. No endpoint the console calls is reachable without a session — exhaustively, across all 88. No refusal leaks a token, a JWT, a secret key, the backend origin or a single row of data. The refusal happens at the Next ingress, before the Clerk JWT is attached and before any upstream request is made.

Does not prove. Anything about behaviour *with* a session: whether scopes are enforced per-role, whether masked grants actually mask, whether `pageSize` is honoured, whether an illegal state transition is refused. Those are the 48 cases above, written and waiting on `npm run e2e:login`.

A refusal is not an endorsement. Every row here says "the door is locked". None says "the room behind it is tidy".